

RaceDay API Endpoint Plan

Method	Route	Description	Role Required	Request Body	Expected Response
POST	/api/auth/register	Registers a new user as an Organiser or Participant	None	{ fullName, email, password, phoneNumber, role }	201 Created – user created / 409 Conflict – email already in use
POST	/api/auth/login	Authenticates a user and issues an access token	None	{ email, password }	200 OK – token + profile / 401 Unauthorized – invalid credentials
GET	/api/users/me	Returns the logged-in user's own profile	Any	None	200 OK – profile / 401 Unauthorized
PUT	/api/users/me	Updates the logged-in user's profile details	Any	{ fullName, phoneNumber }	200 OK – updated profile / 400 Bad Request
GET	/api/events	Lists all published events, for public browsing	None	None	200 OK – array of events
GET	/api/events/{id}	Returns details for a single event	None	None	200 OK – event / 404 Not Found
POST	/api/events	Creates a new event	Organiser	{ name, eventDate, }	201 Created –

		owned by the logged-in Organiser		location, description }	event / 400 Bad Request
PUT	/api/events/{id}	Updates an event owned by the logged-in Organiser	Organiser	{ name, eventDate, location, description, status }	200 OK – updated event / 403 Forbidden – not owner / 404 Not Found
DELETE	/api/events/{id}	Deletes an event owned by the logged-in Organiser	Organiser	None	204 No Content / 403 Forbidden / 404 Not Found
GET	/api/events/{eventId}/categories	Lists all race categories for a given event	None	None	200 OK – array of categories / 404 Not Found
POST	/api/events/{eventId}/categories	Adds a new category to an event owned by the Organiser	Organiser	{ name, distanceKm, maxParticipants, price }	201 Created – category / 400 Bad Request / 403 Forbidden
PUT	/api/categories/{id}	Updates a category owned by the logged-in Organiser	Organiser	{ name, distanceKm, maxParticipants, price }	200 OK – updated category / 403 Forbidden / 404 Not Found
DELETE	/api/categories/{id}	Deletes a category owned by the	Organiser	None	204 No Content / 403 Forbidden / 404

		logged-in Organiser			Not Found
POST	/api/categories/{categoryId}/ enrolments	Enrols the logged-in Participant into a category and assigns a bib number	Participant	None	201 Created – enrolment / 404 Not Found – category / 409 Conflict – already enrolled or category full
GET	/api/users/me/enrolments	Lists all enrolments belonging to the logged-in Participant	Participant	None	200 OK – array of enrolments
GET	/api/categories/{categoryId}/ enrolments	Lists all enrolments for a category, for the owning Organiser	Organiser	None	200 OK – array of enrolments / 403 Forbidden
DELETE	/api/enrolments/{id}	Cancels the logged-in Participant's own enrolment	Participant	None	204 No Content / 403 Forbidden – not owner / 404 Not Found
POST	/api/enrolments/{id}/results	Records a race result for a specific enrolment	Organiser	{ finishTime, position, status }	201 Created – result / 403 Forbidden – not event owner /

					404 Not Found / 409 Conflict – result already recorded
PUT	/api/results/{id}	Updates a previously recorded result	Organiser	{ finishTime, position, status }	200 OK – updated result / 403 Forbidden / 404 Not Found
GET	/api/events/{eventId}/results	Returns the full results list for an event	None	None	200 OK – array of results / 404 Not Found
GET	/api/users/me/results	Returns the logged-in Participant's own results across all events	Participant	None	200 OK – array of results

Design notes

- **Ownership checks (403 Forbidden):** an Organiser may only create, edit, or delete Events, Categories, and Results that they own. This enforces role-based access at the resource level, not just at the endpoint level.
- **Enrolment creation takes no request body:** the category, the enrolling participant (from the auth token), and the assigned bib number are all derived server-side rather than trusted from client input, preventing a participant from enrolling as someone else or self-assigning a bib number.
- **Public read endpoints:** GET /api/events, GET /api/events/{id}, GET /api/events/{eventId}/categories, and GET /api/events/{eventId}/results require no authentication, since spectators and prospective participants should be able to browse events and results without an account.